מחלקת תקשוב · רשתות · מדריך למעביר השיעור

Domain, אימות, הצפנה ותעודות

הסבר לכל שקופית: מה מראים, מה צריך להבין כדי להסביר את זה, אילו שאלות יעלו ואיפה חניכים נוטים לטעות.

17	כ-55 דקות	5 דקות
שקופיות	משך מומלץ	פער שעון שמעליו Kerberos דוחה בקשה

לטכנאי שטח בסביבת Windows מנוהלת · ההרחבה בהצפנה ובתעודות נמצאת בשיעור 8

מטרה, הכנה וחלוקת זמן

למי המדריך ומה המטרה

המדריך כתוב למי שמעביר את השיעור ולא בהכרח ניהל Domain. הרקע בכל שקופית רחב ממה שעל המסך, כדי שתוכלו לענות כשחניך שואל ״למה״.

לעקוב עם הכיתה אחרי כניסת משתמש לתחנה ב-Domain ואחרי חיבור לשירות מאובטח ב-TLS, ולשאול בכל שלב מה חייב לעבוד כדי שהוא יצליח. בסוף השיעור חניך אמור להסביר איך תחנה מוצאת Domain Controller, להפריד בין אימות להרשאה, להסביר למה שעון שגוי מפיל כניסה, להבחין בין הצפנה סימטרית לאסימטרית, לקרוא תעודה ולשייך שגיאת TLS למשפחה שלה: זמן, שם, אמון או משא ומתן. שמות של אלגוריתמים והודעות לא צריך לזכור.

הכנה

- פתחו את המצגת ב-Chrome או ב-Edge במחשב המקרן ועברו על כל השקופיות. אין בה הדגמות ואין צורך ברשת.
- הניווט: חצים או רווח, N הערות המדריך, F מסך מלא, A אנימציות. אין במצגת תיבות טקסט, ולכן המקשים תמיד מנווטים.
- מספרי השקופיות במדריך הם המספרים שבמונה בתחתית המסך (״2 / 17״). המספר הקטן שליד הכותרת נמוך באחד, כי שקופית השער לא ממוספרת.
- ודאו שהקבוצה מכירה DNS, כתובת IP ו-Gateway מהשיעור הקודם, והכינו דוגמה להודעת שגיאה של תעודה או של כניסה ל-Domain, בלי פרטים רגישים.
- עברו מראש על רצף ה-Handshake בשקופית 15. בכיתה מסבירים את סדר השלבים ואת התקלות, בלי לפרק כל הודעה. אם יש תחנה שמחוברת ל-Domain, אפשר להריץ עליה את הפקודות מסעיפי ״בשטח״ (רשימה בנספח).

> **מה לא מלמדים בשיעור הזה**
>
> ניהול Active Directory, כתיבת GPO והקמת CA לא נכללים. מי מתקן ערוץ מאובטח, מצרף תחנה מחדש או משנה מדיניות נקבע בנוהל היחידה.

חלוקת זמן מוצעת (55 דקות)

חלק	שקופיות	מה מעבירים	דקות
פתיחה	1-2	Domain כגבול זהות	5
AD, DNS והצטרפות	3-5	אובייקטים, איתור DC וחשבון מחשב	9
אימות והרשאה	6-9	הרשאות, Kerberos, כרטיסים, זמן ו-Group Policy	10
סוגי הצפנה	10-11	יעדי האבטחה, תפקיד ההצפנה האסימטרית והסימטרית	8
תעודות ומשא ומתן	12-14	תעודה, שרשרת אמון ו-Cipher Suite	10
TLS Handshake	15-16	רצף ההודעות ומשפחות תקלה	10
סגירה	17	שרשרת התלות	3

פתיחה: Domain וה-DC

שקופית 1 · בסביבת Windows, זהות ו-TLS נשענים על DNS, זמן ושרשרת אמון

הציגו את שני התהליכים שהשיעור עוקב אחריהם, כניסה לתחנה וחיבור לשירות מאובטח, ושאלו את שאלת הפתיחה: **איך שעון שגוי יכול לגרום לכניסה להיכשל גם כשהסיסמה נכונה והרשת זמינה?** אל תענו עכשיו. התשובה בשקופית 8. ניהול Domain נשאר מחוץ לשיעור.

שקופית 2 · ב-Domain מנוהלים משתמשים, מחשבים ומדיניות, וה-DC נותן את השירותים

על המסך: Domain Controller במרכז (זהות, DNS, מדיניות), ומסביבו משתמש, תחנה, קבוצה ושרת. כולם נשענים על אותו DC.

רקע. בלי Domain, כל מחשב Windows מחזיק רשימת משתמשים משלו, ומי שעובד על עשר תחנות צריך עשרה חשבונות. ב-Domain יש מאגר זהויות אחד, Active Directory, והמחשבים סומכים עליו: משתמש נכנס לכל תחנה בחשבון אחד, וההרשאות והמדיניות מוגדרות במקום אחד.

Domain Controller הוא שרת שמחזיק עותק של המאגר ומספק את השירותים: אימות (Kerberos), שאילתות על המאגר (LDAP), ובדרך כלל גם DNS. ברוב הרשתות יש יותר מ-DC אחד, והם משכפלים ביניהם שינויים, כך שנפילה של אחד לא עוצרת כניסות.

ההערות מבקשות שתי הבחנות. **Domain ו-DNS Domain:** ל-Domain של AD יש שם DNS (למשל unit.local), אבל שם DNS לבדו, כמו כתובת של אתר, הוא רק מרחב שמות, בלי משתמשים, סיסמאות או מדיניות. **Domain ו-Subnet:** Subnet ו-VLAN הם חלוקה של הרשת, ו-Domain הוא חלוקה ניהולית. שתי תחנות באותו Subnet יכולות להיות ב-Domain שונה, ותחנה שעוברת ל-VLAN אחר נשארת חברה ב-Domain שלה. השייכות נקבעת בניהול וביחסי האמון.

בשטח. whoami מראה בשם מי מחוברים: UNIT\user הוא חשבון Domain, ושם התחנה לפני הלוכסן מסמן חשבון מקומי. echo %LOGONSERVER% מראה איזה DC אימת את הכניסה.

שאלה	תשובה
אם מעבירים תחנה ל-VLAN אחר, היא יוצאת מה-Domain?	היא נשארת חברה. אבל אם מה-VLAN החדש אין דרך ל-DC או ל-DNS שלו, היא לא תוכל להשתמש בשירותים שלו.

אובייקטים, DNS והצטרפות ל-Domain

שקופית 3 · ב-Active Directory יש חשבון גם למשתמש וגם למחשב

על המסך: Active Directory כספריית אובייקטים: משתמשים, מחשבים, קבוצות ומדיניות.

רקע. כל מה שה-Domain מכיר הוא אובייקט במאגר, ולכל אובייקט יש מזהה ייחודי (SID). ההרשאות על קבצים נשמרות לפי ה-SID, ולכן משתמש שנמחק ונוצר מחדש באותו שם מקבל SID חדש, וההרשאות הישנות לא חוזרות אליו. קבוצות מחברות בין זהות לגישה: נותנים הרשאה לקבוצה ומוסיפים אליה משתמשים. מדיניות (GPO) היא אובייקט שמקושר לחלק מעץ ה-AD (שקופית 9).

מה שהחניך צריך להכיר הוא **אובייקט המחשב**. תחנה שהצטרפה ל-Domain מחזיקה חשבון משלה (בשם התחנה, עם $ בסוף) וסיסמה שהיא וה-DC מכירים. את הסיסמה הזו התחנה מחליפה בעצמה, בברירת מחדל פעם ב-30 יום. אם החשבון נמחק, או שהסוד שבתחנה כבר לא תואם את ה-DC, התחנה נתקלת בבעיות מול ה-Domain. מקרה אופייני: תחנה ששוחזרה מגיבוי או מתמונה ישנה חוזרת עם סיסמה שכבר הוחלפה. ההודעה בכניסה היא בדרך כלל The trust relationship between this workstation and the primary domain failed.

תכנון OU וניהול הרשאות לא נכנסים כאן.

שקופית 4 · תחנה מאתרת Domain Controller באמצעות DNS

על המסך: התחנה שואלת את ה-DNS מי מספק Kerberos, מקבלת DC01.domain מרשומות SRV ופונה ל-DC.

רקע. רשומת A מתרגמת שם לכתובת. רשומת SRV עונה על שאלה אחרת: איזה שרת נותן שירות מסוים ובאיזה פורט. כל DC רושם ב-DNS רשומות כאלה על עצמו, למשל _ldap._tcp.dc._msdcs.unit.local. תחנה שצריכה DC שואלת עליהן, מקבלת רשימת DC-ים ופונה לאחד מהם, בדרך כלל לקרוב אליה.

הרשומות נמצאות רק ב-DNS של ה-Domain. לכן תחנה עם DNS ציבורי יכולה לגלוש באינטרנט ועדיין להפיל את ה-Domain, כי דרכו היא לא מאתרת את ה-DC. מבלבל יותר: DNS ראשי פנימי ומשני חיצוני. כשהראשי לא עונה בזמן, התחנה פונה למשני, מקבלת "אין רשומה כזו", והתקלה מופיעה ונעלמת. מההערות: כשיש IP אבל הכניסה ל-Domain נכשלת, אחד החשודים הראשונים הוא DNS שגוי.

בשטח. ipconfig /all מראה אילו שרתי DNS התחנה מקבלת. nltest /dsgetdc:unit.local (עם שם ה-Domain האמיתי) מריץ את תהליך האיתור ומחזיר את ה-DC שנמצא.

> **טעות נפוצה**
>
> "יש ping ל-DC, אז DNS תקין". Ping לכתובת IP בודק רק את הנתיב ברשת, ולא את השאלה אם ה-DNS של התחנה מכיר את רשומות ה-SRV.

שקופית 5 · Domain Join יוצר למחשב חשבון וערוץ מאובטח

על המסך: תחנה חדשה עם זהות מקומית שולחת בקשת הצטרפות, ה-DC יוצר חשבון מחשב וסוד משותף, והתוצאה היא תחנת Domain עם ערוץ מאובטח.

רקע. בהצטרפות התחנה מאתרת DC דרך DNS, מי שמבצע את ההצטרפות מזדהה בחשבון שמותר לו לצרף מחשבים, ונוצר אובייקט מחשב. התחנה וה-DC קובעים לו סיסמה, וזה הסוד המשותף שבתרשים. אחרי אתחול התחנה פותחת בעזרתו ערוץ מאובטח (Secure Channel) מול DC, ומעכשיו היא עצמה יכולה להזדהות: היא מקבלת מדיניות מחשב עוד לפני שמשתמש נכנס, ומאמתת מול ה-DC משתמשים שמקלידים סיסמה.

הרצף כולו: DNS מתאים ← איתור DC ← חשבון מחשב ← ערוץ מאובטח ← קבלת מדיניות. כשמשהו נשבר, הולכים עליו מההתחלה.

כניסה מה-Cache. Windows שומר נתוני אימות של הכניסות האחרונות (בברירת מחדל עשר), כדי שמשתמש במחשב נייד יוכל להיכנס גם בלי חיבור ל-DC. לכן, כמו שכתוב בהערות, אם הערוץ המאובטח נשבר, המשתמש עשוי להיכנס עם Cache, אבל פעולות Domain אחרות ייכשלו: כוננים ממופים, מדיניות, גישה לשרתים.

בשטח. Test-ComputerSecureChannel ב-PowerShell בודק את הערוץ ומחזיר True או False. תיקון או הצטרפות מחדש דורשים הרשאות ב-Domain, ומי מבצע אותם נקבע בנוהל היחידה.

אימות, Kerberos, זמן ומדיניות

שקופית 6 · אימות בודק מי המשתמש, והרשאה קובעת מה מותר לו

על המסך: אימות שואל ״מי אתה?״ ומוציא זהות מאומתת. הרשאה שואלת ״מה מותר לך?״ לפי קבוצות, ACL ומדיניות.

רקע. אימות מסתיים כשהמערכת יודעת מי המשתמש. הרשאה נבדקת בכל גישה למשאב. בכניסה Windows בונה למשתמש ״אסימון גישה״ עם ה-SID שלו ושל כל הקבוצות שלו, ובכל פתיחה של תיקייה משווה אותו לרשימת ההרשאות (ACL) שלה. בתיקייה משותפת יש שתי רשימות, הרשאות השיתוף והרשאות NTFS, והגישה בפועל היא המחמירה מביניהן.

מכאן תקלה נפוצה: מוסיפים משתמש לקבוצה, והוא עדיין לא נכנס לתיקייה. האסימון נבנה בכניסה, ולכן הקבוצה החדשה נכנסת לתוקף בדרך כלל רק אחרי יציאה וכניסה מחדש. whoami /groups מציג את הקבוצות שבאסימון הנוכחי.

שאלת ביניים

משתמש נכנס לתחנה אך אינו פותח תיקייה. האם זו בהכרח בעיית סיסמה? הכניסה הצליחה, כלומר האימות עבר. התקלה בהרשאה, ואינה בהכרח קשורה לסיסמה או לקשר ל-DC.

טעות נפוצה

לאפס סיסמה כדי לפתור בעיית גישה לתיקייה. איפוס סיסמה לא נוגע בהרשאות, והמשתמש נכנס עם סיסמה חדשה ועדיין לא פותח את התיקייה.

שקופית 7 · Kerberos משתמש בכרטיסים כדי להוכיח זהות לשירותים

על המסך: המשתמש מבקש כרטיס מה-KDC שב-DC, מקבל Ticket ומציג אותו לשרת השירות. הסיסמה לא נשלחת לשרת.

רקע. Kerberos היא שיטת האימות של Domain ב-Windows מאז Windows 2000. הרעיון דומה לאישור כניסה לבסיס: מזדהים פעם אחת, מקבלים אישור מוגבל בזמן, ומציגים אותו בכל שער. השירות שמנפיק את הכרטיסים, KDC, רץ על כל DC. בפועל יש שני שלבים, והתרשים מאחד אותם:

- בכניסה התחנה מוכיחה שהמשתמש יודע את הסיסמה בלי לשלוח אותה: היא מצפינה את השעה הנוכחית במפתח שנגזר מהסיסמה, וה-KDC בודק שהוא מצליח לפענח. בתמורה היא מקבלת כרטיס ראשי (TGT), בברירת מחדל לעשר שעות.
- כשניגשים לשירות, למשל לשרת קבצים, התחנה מציגה את הכרטיס הראשי ומקבלת כרטיס לשירות המסוים. אותו היא מציגה לשרת, והשרת בודק אותו בעצמו בלי לפנות ל-DC.

הסיסמה לא נשלחת לשרת וגם לא ל-DC. בכרטיס יש גם את קבוצות המשתמש, שעליהן מבוססת ההרשאה. כרטיס שירות מונפק לשם של השירות, ולכן Kerberos צריך שמות תקינים. בגישה לפי כתובת IP, למשל \\10.0.0.5\share, Windows בדרך כלל עובר לשיטה הישנה, NTLM, ואם היא חסומה, הגישה נכשלת. בהערות: אין צורך בשמות כל הכרטיסים. הדגישו ש-DNS וזמן נדרשים לפני שהכרטיס יכול לעבוד.

כניסה בכרטיס חכם עוברת גם היא ב-Kerberos, בגרסה מבוססת תעודות שנקראת PKINIT (שיעור 8, שקופית 13).

בשטח. klist מציג את הכרטיסים שיש למשתמש, למי הונפקו ועד מתי הם תקפים. klist purge מוחק אותם, והתחנה מבקשת חדשים בגישה הבאה.

שקופית 8 · שעון שגוי נראה כמו תקלה באימות

על המסך: שעון התחנה ושעון ה-DC מראים שעות שונות, וביניהם ״פער זמן: Ticket עלול להידחות״.

רקע. זו התשובה לשאלת הפתיחה. ב-Kerberos ההוכחה שהתחנה שולחת בכניסה היא השעה המוצפנת, וכל כרטיס תקף בין שתי שעות. כדי שהקלטה ישנה לא תתקבל, ה-DC דוחה בקשות כשהפער בין השעונים גדול מחמש דקות (ברירת המחדל). הסיסמה נכונה והרשת זמינה, והכניסה נכשלת. Windows מציג לפעמים הודעה על הפרש שעה ותאריך בין הלקוח לשרת, ולפעמים רק שגיאת אימות כללית.

ההשוואה נעשית בזמן אוניברסלי (UTC). אזור זמן שגוי לבדו לא מפיל את Kerberos. הבעיה מתחילה כשמשתמש ״מתקן״ ידנית את השעה המוצגת בתחנה עם אזור זמן שגוי, והשעון האמיתי זז בשעות.

ב-Domain השעה מגיעה בהיררכיה: התחנות מסתנכרנות מול ה-DC, וה-DC-ים מסתנכרנים בסופו של דבר מול DC אחד, שמחזיק תפקיד שנקרא PDC Emulator ומקבל שעה ממקור שנקבע לרשת. מהו המקור ביחידה נקבע בנוהל היחידה.

מההערות: זמן מערכת שגוי יכול לגרום גם לתעודה להיראות ״טרם בתוקף״ או ״פגה״, כי הדפדפן משווה את תאריכי התעודה לשעון המקומי (שקופית 16).

בשטח. w32tm /query /status מראה מתי התחנה הסתנכרנה לאחרונה, ו-w32tm /query /source ממי היא מקבלת שעה. ״Local CMOS Clock״ כמקור אומר שהיא לא מסתנכרנת בכלל. סוללת שעון מרוקנת בלוח האם מחזירה את התאריך אחורה אחרי ניתוק מהחשמל.

טעות נפוצה

לשנות ידנית את השעה ב-DC כדי ״ליישר״ תחנה אחת. שינוי כזה מזיז את כל ה-Domain ביחס למקור הזמן. התיקון הוא בתחנה שסוטה, בסנכרון מול ה-Domain.

שקופית 9 · מדיניות Domain יכולה לשנות שירותים, חומת אש ואמון בתחנה

על המסך: ה-DC מפיץ Group Policy עם הגדרות שירות, חומת אש ותעודות ואמון, והתחנה מקבלת אותה בעדכון ובריענון.

רקע. GPO יכול להפעיל או לבטל שירותים, לפתוח או לחסום פורטים בחומת האש, למפות כוננים, להתקין תעודות שורש פנימיות (שקופית 13) ולנעול הגדרות. מדיניות המחשב נטענת בעליית התחנה, מדיניות המשתמש בכניסה, ושתיהן מתרעננות ברקע, בברירת מחדל כל 90 דקות בערך. לכן, כמו בכותרת המשנה, הגדרה שרואים בתחנה לא בהכרח שונתה בה ידנית. הגדרה כזו מופיעה לרוב באפור, עם הודעה שחלק מההגדרות מנוהלות על ידי הארגון, ומי שמשנה אותה ידנית יגלה שהיא חוזרת בריענון הבא.

בשטח. מהטכנאי מצופה לאסוף gpresult ולבדוק אם המדיניות התקבלה בתחנה. gpresult /r מציג אילו GPO הוחלו (את חלק המחשב רואים רק בחלון עם הרשאות מנהל), ו-gpresult /h report.html מפיק דוח מלא שאפשר להעביר הלאה. gpupdate /force מושך את המדיניות מיד. כשמדיניות לא מגיעה, בדרך כלל התחנה לא מגיעה ל-DC (חוזרים לשקופיות 4-5). ניהול ה-GPO עצמו אינו בתחום של הטכנאי.

יעדי האבטחה וסוגי הצפנה

שקופית 10 · חיבור מאובטח צריך סודיות, שלמות ואימות זהות

על המסך: סודיות (מי שאין לו מפתח אינו קורא), שלמות (שינוי בתעבורה מתגלה), אימות (הלקוח בודק את זהות השרת). TLS מספק את שלושתם.

רקע. ההערות מבקשות להציג את היעדים לפני האלגוריתמים, כי כל רכיב ב-TLS קיים בשביל אחד מהם. שלמות פחות מובנת לחניכים: בלי בדיקת שלמות, תוקף שלא יודע לקרוא את התעבורה עדיין יכול לשנות בה ביטים, והצד השני יקבל מידע משובש בלי לדעת. לכן TLS מצרף לכל רשומה תג שמגלה שינוי.

הדגישו את האימות, כי בשבילו TLS צריך תעודה. אם מישהו ברשת מתחזה לשרת והלקוח רק מצפין, הלקוח יקים חיבור מוצפן מצוין עם המתחזה. הצפנה לבדה אינה מוכיחה שהצד השני הוא השרת הנכון. את זה מוכיחות התעודה וחתימת השרת (שקופיות 12-15). Kerberos עונה על אותה דרישה ב-Domain, בכרטיסים במקום תעודות.

מה הסמל בשורת הכתובת של הדפדפן מבטיח ומה לא מוסבר בשיעור 8, שקופית 9.

שקופית 11 · הצפנה אסימטרית ב-Handshake, סימטרית לתעבורה

על המסך: אסימטרית: מפתח ציבורי ומפתח פרטי שנשאר אצל הבעלים, לזהות ולהסכמה על סוד משותף. סימטרית: אותו מפתח זמני בשני הצדדים, מהיר לתעבורה.

רקע. בהצפנה **סימטרית** אותו מפתח מצפין ומפענח. היא מהירה, ולכן מצפינים בה את המידע עצמו, בדרך כלל ב-AES. הבעיה שלה היא איך שני הצדדים מגיעים לאותו מפתח. בהצפנה **אסימטרית** לכל צד יש זוג מפתחות: הציבורי מתפרסם, והפרטי נשאר אצל בעליו. מה שנחתם במפתח הפרטי, כל אחד בודק במפתח הציבורי. היא איטית בסדרי גודל, ולכן משמשת רק בתחילת החיבור.

ב-Handshake של TLS 1.3 שני הצדדים מחליפים חצאים ציבוריים בשיטת דיפי-הלמן (ECDHE), וכל אחד מחשב מהם את אותו סוד. מי שמאזין רואה את שני החצאים ולא יכול לחשב את הסוד. בנוסף השרת חותם במפתח הפרטי של התעודה שלו, וכך מוכיח שהוא בעליה. מהסוד המשותף כל צד גוזר אצלו את מפתחות ה-Session, זמניים לחיבור אחד, ומשם התעבורה סימטרית.

ההערות מבקשות: אל תגידו שמפתח ה-Session פשוט נשלח ברשת. שני הצדדים גוזרים סוד משותף בלי לחשוף אותו. אם חניך מכיר את השיטה הישנה של TLS 1.2, שבה הלקוח הצפין סוד במפתח הציבורי של השרת ושלח אותו, ספרו לו שב-TLS 1.3 היא בוטלה: מי שהקליט תעבורה והשיג אחר כך את המפתח הפרטי של השרת יכול היה לפענח את ההקלטות. להרחבה: שיעור 8, שקופיות 6-8 ו-25.

תעודה, שרשרת אמון ו-Cipher Suite

שקופית 12 · תעודה קושרת שם למפתח ציבורי, והמנפיק חותם עליה

על המסך: תעודה לדוגמה: השם server.unit, מפתח ציבורי, המנפיק Unit-CA, תוקף 2026-2027 וחתימת המנפיק.

רקע. מפתח ציבורי לבדו הוא רצף מספרים בלי בעלים. התעודה קובעת "המפתח הזה שייך ל-server.unit", ורשות תעודות (CA) חותמת על הקביעה. הלקוח סומך על החתימה של ה-CA, ודרכה על השם שבתעודה.

בחלון התעודה של Windows רואים את השמות שהתעודה תקפה להם (Subject, ובעיקר Subject Alternative Name, הרשימה היחידה שדפדפנים מודרניים בודקים), את המפתח הציבורי, את המנפיק ואת תאריכי התוקף. תעודות של אתרים ציבוריים מונפקות היום לתקופה קצרה משנה (מאז מרץ 2026 עד 200 יום, והתקופה ממשיכה להתקצר), ותעודות של CA פנימי לפי מדיניות הארגון. המפתח הפרטי נשאר בשרת ואינו חלק מהתעודה.

הלקוח בודק שם, תוקף, מנפיק וחתימה לפני שהוא סומך על השירות. ההערות מבקשות להפריד בין התעודה, שהיא ציבורית, לבין המפתח הפרטי שנשאר אצל בעל הזהות, ולבין שרשרת האמון. אל תיכנסו למתמטיקה.

בשטח. בדפדפן פותחים את התעודה מהסמל שבתחילת שורת הכתובת: מנעול ב-Edge, וב-Chrome, מאז 2023, סמל הגדרות במקום המנעול. ב-Windows מאגר התעודות של המחשב נפתח ב-certlm.msc.

שאלה	תשובה
אם התעודה ציבורית, מה מונע ממני להעתיק אותה לשרת שלי?	כלום, אבל בלי המפתח הפרטי השרת לא יוכל להוכיח שהיא שלו, וה-Handshake ייכשל (שקופית 15).

> **טעות נפוצה**
>
> חניך מסביר שהתעודה "מצפינה את התעבורה". התעודה קושרת שם למפתח ציבורי. את התעבורה מצפין מפתח Session סימטרי שנגזר ב-Handshake.

שקופית 13 · אמון נבנה מהתעודה דרך מנפיקים עד Root מוכר

על המסך: Root CA (עוגן אמון מקומי), Intermediate CA חתום על ידי ה-Root, ותעודת שרת חתומה על ידי ה-CA. הלקוח בונה שרשרת עד לעוגן שהוא כבר סומך עליו.

רקע. הלקוח בודק מי חתם על תעודת השרת, ואז מי חתם על החותם, עד תעודת Root. ה-Root חתום בידי עצמו, וסומכים עליו רק כי הוא מותקן מראש במאגר האמון (Trusted Root Certification Authorities). שורשים ציבוריים מגיעים עם Windows ועם העדכונים שלו. שורש פנימי מגיע לתחנות ה-Domain בדרך כלל דרך מדיניות (שקופית 9), ולכן תחנה שהמדיניות לא הגיעה אליה לא תסמוך על אתרים פנימיים.

שכבת ה-Intermediate קיימת כדי שהמפתח של ה-Root יישמר מנותק ומוגן. כמו בהערות, Intermediate יכול להגיע עם השירות, כשהשרת שולח אותו יחד עם התעודה שלו, או להיות מותקן בנפרד. כשהשרת לא שולח אותו, חלק מהלקוחות מורידים אותו לבד מכתובת שרשומה בתעודה, וחלק לא, וברשת סגורה ההורדה נכשלת. זו תקלה ש"עובדת אצלי" ולא אצל אחר. חוליה חסרה או Root שאינו מהימן שוברים את השרשרת.

בשטח. הלשונית Certification Path בחלון התעודה מציגה את השרשרת ומסמנת חוליה בעייתית.
certutil -verify -urlfetch server.cer בודק את כל השרשרת ואת זמינות כתובות הביטול. בשיעור 8, שקופית 11, יש בודק שרשרת עם תרחישי תקלה.

שקופית 14 · הלקוח מציע אפשרויות, והשרת בוחר שילוב ששניהם תומכים בו

על המסך: ה-ClientHello מציע שלושה Cipher Suites, והשרת בוחר TLS_AES_128_GCM_SHA256, שמתפרק ל-AES_128_GCM (הצפנה סימטרית ושלמות) ול-SHA256 (Hash וגזירת מפתחות).

רקע. כל חיבור מתחיל במשא ומתן: הלקוח שולח רשימה של מה שהוא יודע, והשרת בוחר אפשרות אחת שגם הוא תומך בה. ב-TLS 1.3 שם ה-Cipher Suite מתאר רק את הצפנת התעבורה, שמוסיפה לכל רשומה גם תג שלמות, ואת ה-Hash. CHACHA20_POLY1305 מיועד בעיקר למכשירים בלי האצת AES בחומרה. חוץ מה-Cipher Suite מסכמים בנפרד על גרסה, על Key Exchange ועל אלגוריתם החתימה. ב-TLS 1.2 הכול היה בשם אחד ארוך, למשל TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256, וכאלה עדיין מופיעים בהגדרות של ציוד ישן.

את שמות האלגוריתמים לא צריך לזכור. החניך צריך להבין שאם אין התאמה, החיבור נופל עוד לפני שעובר מידע: השרת שולח הודעת שגיאה וסוגר, ו-Chrome ו-Edge מציגים ERR_SSL_VERSION_OR_CIPHER_MISMATCH.

בשטח. המקרה הנפוץ הוא ממשק ניהול של ציוד ישן (מדפסת, UPS, מתג) שתומך רק ב-TLS 1.0 או 1.1, שהדפדפנים כבר לא מסכימים להשתמש בהם. המקרה ההפוך הוא שרת שהוקשח ומסרב ללקוח ישן. ב-Windows כשלים של רכיבים שמשתמשים ב-TLS של מערכת ההפעלה (למשל שרת IIS, RDP או LDAPS) נרשמים ביומן System, במקור Schannel. Chrome ו-Edge משתמשים ברכיב TLS משלהם, והכשלים שלהם לא נרשמים שם.

TLS Handshake, תקלות ושרשרת התלות

שקופית 15 · ה-Handshake מאמת את השרת וגוזר מפתחות לפני שעובר מידע יישומי

על המסך: תרשים הודעות בין לקוח לשרת, מה-ClientHello ועד Application Data מוצפנת סימטרית. בתחתית: "SSL" הוא השם הישן, הפרוטוקול הוא TLS.

רקע. כאן מתחבר כל מה שנלמד עד עכשיו. עברו על הרצף לפי הסדר:

שלב	כיוון	מה עובר ולמה
1	מהלקוח	ClientHello: גרסאות, Cipher Suites, החצי הציבורי של דיפי-הלמן (key share) ושם השרת המבוקש.
2	מהשרת	ServerHello: מה שנבחר והחצי של השרת. מעכשיו שני הצדדים יכולים לחשב את הסוד המשותף.
3	מהשרת	Certificate: התעודה והשרשרת. CertificateVerify: חתימה במפתח הפרטי על ההודעות עד כה, שמוכיחה שהשרת מחזיק את המפתח של התעודה.
4	בלקוח	אימות שם, תוקף, שרשרת וחתימה. כאן נולדות שגיאות התעודה.
5	בשני הכיוונים	Finished: כל צד מוכיח שראה את אותן הודעות והגיע לאותם מפתחות. תוקף ששינה הודעה בדרך נתפס כאן.
6	דו-כיווני	Application Data מוצפנת סימטרית במפתחות ה-Session.

התרשים מפשט נקודה אחת: ב-TLS 1.3 הצדדים גוזרים מפתחות ראשונים כבר אחרי ה-ServerHello, וכל מה שהשרת שולח מהתעודה והלאה עובר מוצפן. מפתחות התעבורה עצמה נגזרים בסוף ה-Handshake. לכיתה מספיק הסדר שבתרשים: הסכמה, הוכחת זהות, ואז מידע.

SSL ו-TLS. אם חניך אומר SSL, זה השם הישן שנשאר בדיבור. כל גרסאות SSL משנות ה-90 נשברו ובוטלו, ובשימוש היום TLS 1.2, שפורסם ב-2008, ו-TLS 1.3, שפורסם ב-2018. TLS נמצא גם ב-LDAPS מול ה-DC, ב-RDP וב-VPN, עם אותן תקלות. אין צורך להעמיק במתמטיקה או בכל הודעת משנה. התמונה המלאה בשיעור 8, שקופיות 27-28.

שקופית 16 · בתקלת TLS בודקים זמן, שם, אמון ומשא ומתן

על המסך: ארבע משפחות: זמן או תוקף (שעון או תאריך שגוי), שם לא תואם (פנו בשם אחר), שרשרת לא מהימנה (Intermediate או Root), אין התאמה (גרסה או Cipher Suite).

רקע. כל משפחה נשברת בשלב אחר, ולכן הודעת השגיאה והשעה מצביעות על השלב שנשבר. שלוש הראשונות הן כשל באימות התעודה (שלב 4 בטבלה הקודמת). הרביעית היא כשל במשא ומתן, בשלבים 1-2, עוד לפני שהתעודה נשלחה. ההערות מבקשות להפריד בין שני הסוגים.

משפחה	שגיאה אופיינית ב-Chrome וב-Edge	מה בודקים
זמן או תוקף	ERR_CERT_DATE_INVALID	תאריכי התעודה מול שעון התחנה. אם רק תחנה אחת נכשלת, החשוד הוא השעון שלה.

שם לא תואם	ERR_CERT_COMMON_NAME_INVALID	מה הוקלד מול רשימת ה-SAN. בדרך כלל נכנסו בכתובת IP או בשם קצר.
שרשרת לא מהימנה	ERR_CERT_AUTHORITY_INVALID	הלשונית Certification Path, וה-Root הפנימי ב-certlm.msc.
אין התאמה	ERR_SSL_VERSION_OR_CIPHER_MISMATCH	גרסת TLS ו-Cipher Suites בשני הצדדים, אירועי Schannel.

לפני כל אלה מוודאים שהבעיה באמת ב-TLS: Test-NetConnection server -Port 443 ב-PowerShell. אם TcpTestSucceeded הוא True, הרשת והפורט תקינים והתקלה בשכבה שמעל.

בשטח. הודעת שגיאה מדויקת ותאריך המערכת חשובים יותר מצילום מסך חלקי. כשמעבירים תקלה הלאה, רושמים את נוסח השגיאה המלא, את השם שהוקלד, את התאריך והשעה בתחנה, ובכמה תחנות היא מופיעה. למי מעבירים נקבע בנוהל היחידה. פירוט לכל שגיאה בשיעור 8, שקופית 12.

לא לוחצים "המשך בכל זאת"

אזהרת התעודה היא בדיוק המצב שהבדיקה נועדה לעצור: ייתכן שהצד השני אינו השרת. מתעדים את השגיאה ומתקנים את החוליה שנכשלה.

שקופית 17 · בלי רשת, DNS, זמן וזהות תקינים, Domain ו-TLS לא יעבדו

על המסך: חמש עמודות: רשת (Link, IP ונתיב), DNS (איתור DC ושירות), זמן (תוקף כרטיס ותעודה), זהות (משתמש ומחשב), TLS (אמון ומשא ומתן).

סיימו בתלות בין התשתיות, בלי לחזור על כל המושגים. כל עמודה נשענת על אלה שלפניה: בלי רשת אין DNS, בלי DNS לא מוצאים DC, בלי שעון נכון כרטיסים ותעודות נדחים, ובלי זהות תקינה אין אימות. לכן תקלה באימות מתחילה הרבה פעמים בתשתית אחרת, ובודקים מלמטה למעלה. אפשר לבקש מחניך לענות עכשיו על שאלת הפתיחה בעזרת העמודות.

שאלת סיום

השרת נגיש ב-IP ובפורט, אבל TLS נכשל. מה בודקים לפני שמאשימים את היישום? תשובה טובה עוברת על המשפחות משקופית 16: שעון התחנה ותוקף התעודה, השם שבו פנו מול השמות שבתעודה, השרשרת עד Root מהימן, והתאמה של גרסה ו-Cipher Suite.

מפת המצגת, פקודות ומילון

מפת המצגת

מס׳	כותרת השקופית	מס׳	כותרת השקופית
1	בסביבת Windows, זהות ו-TLS נשענים על DNS, זמן ושרשרת אמון	10	חיבור מאובטח צריך סודיות, שלמות ואימות זהות
2	ב-Domain מנוהלים משתמשים, מחשבים ומדיניות, וה-DC נותן את השירותים	11	הצפנה אסימטרית ב-Handshake, סימטרית לתעבורה
3	ב-Active Directory יש חשבון גם למשתמש וגם למחשב	12	תעודה קושרת שם למפתח ציבורי, והמנפיק חותם עליה
4	תחנה מאתרת Domain Controller באמצעות DNS	13	אמון נבנה מהתעודה דרך מנפיקים עד Root מוכר
5	Domain Join יוצר למחשב חשבון וערוץ מאובטח	14	הלקוח מציע אפשרויות, והשרת בוחר שילוב ששניהם תומכים בו
6	אימות בודק מי המשתמש, והרשאה קובעת מה מותר לו	15	ה-Handshake מאמת את השרת וגוזר מפתחות לפני שעובר מידע יישומי
7	Kerberos משתמש בכרטיסים כדי להוכיח זהות לשירותים	16	בתקלת TLS בודקים זמן, שם, אמון ומשא ומתן
8	שעון שגוי נראה כמו תקלה באימות	17	בלי רשת, DNS, זמן וזהות תקינים, Domain ו-TLS לא יעבדו
9	מדיניות Domain יכולה לשנות שירותים, חומת אש ואמון בתחנה		

פקודות שמוזכרות במדריך

במצגת אין הדגמות עם תוצאה קבועה. אם מריצים פקודות על תחנה בכיתה, אלה הפקודות שהמדריך מזכיר. כולן קוראות מידע בלבד, חוץ מ-gpupdate ו-klist purge, שמרעננים מדיניות וכרטיסים.

פקודה	מה היא מראה	שקופית
echo %LOGONSERVER% · whoami	בשם מי מחוברים, ואיזה DC אימת	2
nltest /dsgetdc:<domain> · ipconfig /all	שרתי ה-DNS של התחנה, ואיתור DC	4
Test-ComputerSecureChannel	מצב הערוץ המאובטח	5
whoami /groups	הקבוצות באסימון הנוכחי	6
klist purge · klist	כרטיסי Kerberos ותוקפם, ומחיקתם	7

w32tm /query /status · **w32tm /query /source**	הסנכרון האחרון ומקור הזמן	8
gpupdate /force · **gpresult /h** · **gpresult /r**	אילו GPO הוחלו, דוח מלא, ריענון	9
certutil -verify -urlfetch · **certlm.msc**	מאגר התעודות של המחשב, ובדיקת שרשרת	12-13
Test-NetConnection -Port 443	האם הפורט פתוח, לפני שחושדים ב-TLS	16

מילון קצר

מונח	הסבר	מונח	הסבר
Domain	גבול ניהולי של זהות, אמון ומדיניות.	**CA**	רשות שחותמת על תעודות.
SRV	רשומת DNS שמצביעה על שרת של שירות ועל הפורט שלו.	**SAN**	רשימת השמות שהתעודה תקפה להם.
Secure Channel	הערוץ המאובטח בין התחנה ל-DC, על בסיס סיסמת חשבון המחשב.	**Cipher Suite**	ב-TLS 1.3: הצפנת התעבורה וה-Hash שנבחרו.
Kerberos / TGT	אימות בכרטיסים מוגבלי זמן / הכרטיס הראשי שמתקבל בכניסה.	**ECDHE**	דיפי-הלמן זמני: הסכמה על סוד בלי לשלוח אותו.
NTLM	שיטת אימות ישנה, שמשמשת כשאין Kerberos.	**מפתח Session**	מפתח סימטרי זמני לחיבור אחד.
GPO	אובייקט מדיניות שמוחל על מחשבים ומשתמשים.	**Handshake**	הסכמה ואימות לפני מידע יישומי.